API REST del Sistema FCT

URL y autenticación

El punto de entrada de la API es `public/api.php`; la ruta del recurso se envía en el parámetro `path`. En este checkout, servido desde XAMPP dentro de `htdocs`, una consulta directa usa:

```
http://localhost/proyecto-practicas/public/api.php?path=ofertas
```

Si la carpeta local tiene otro nombre, sustituye `proyecto-practicas`. En Docker Apache, cuyo document root apunta a `public/`, la forma directa es `http://localhost:8080/api.php?path=ofertas`.

El alias de rutas `/api/v1/...` lo implementa `public/dev-router.php` y puede usarse con el servidor integrado de PHP, por ejemplo `php -S 127.0.0.1:8002 -t public public/dev-router.php`. El `.htaccess` y el VirtualHost Apache incluidos no configuran ese alias. En Apache usa `api.php?path=...` o añade una regla de reescritura en la configuración del servidor antes de usar el alias. Las rutas de esta API están implementadas en `public/api.php`, no en `routes/web.php`.

Antes de usarla en una base ya existente, importa la migración:

```
Get-Content -Raw database\migrations\008_api_access_tokens.sql |
    & 'C:\xampp\mysql\bin\mysql.exe' -h 127.0.0.1 -uroot --database=sistema_fct
```

En el panel de administración abre **Tokens API**, crea un token para la cuenta que corresponda y guárdalo en un gestor seguro: el token completo solo se muestra una vez. La API aplica el rol actual de esa cuenta, limita los recursos de Empresa a su empresa y los de Alumno a su propio expediente. Desactivar o eliminar la cuenta invalida sus tokens; el administrador también puede revocarlos explícitamente. En la base solo se guarda el hash SHA-256.

En **Integraciones**, Administración dispone de una consola para introducir el token y enviar solicitudes manuales. El probador API llama al alias `/api/v1/`, por tanto requiere un servidor configurado con esa reescritura; el Apache incluido en Docker no la configura. El token solo se usa en la solicitud del navegador y no se guarda en el servidor. Las operaciones POST y PATCH modifican la base de datos actual; usa únicamente registros de prueba y revisa el cuerpo antes de confirmar.

La página **Integraciones** reúne la consola para probar esta API. El panel de tokens sigue disponible desde la propia consola. En Docker Apache, usa la ruta directa `api.php?path=...`; el alias `/api/v1/` requiere configurar el servidor. Consulta la Guía de Integraciones.

Envía el token en cada solicitud mediante `Authorization: Bearer <API_TOKEN>`. Sustituye el marcador por el token creado en **Tokens API**; no lo incluyas en una URL ni lo confirmes en el repositorio.

```
Authorization: Bearer <API_TOKEN>
```

Recursos y permisos

Todas las rutas requieren token. Las listas se paginan con `page` y `per_page` (por defecto 1 y 50; máximo 100). La API utiliza el mismo sobre discriminado que `JsonResponse`: éxito `{ "success": true, "data": T }` y error `{ "success": false, "error": "..." }`. En una lista, `T` contiene `items` y `meta` (`data.items` y `data.meta`, con `page`, `per_page`, `total`); una respuesta de detalle o escritura coloca el objeto en `data`. Los errores incluyen el código estable en la cabecera HTTP `X-API-Error-Code`; el cuerpo `error` es un mensaje de texto.

Ejemplo de una lista vacía:

```
{
  "success": true,
  "data": {
    "items": [],
    "meta": { "page": 1, "per_page": 50, "total": 0 }
  }
}
```

Ejemplo de error:

```
{ "success": false, "error": "El recurso solicitado no existe." }
```

Método	Ruta	Permiso y acción
GET	`/alumnos` y `/alumnos/{id}`	Administrador, Coordinador y Observador consultan; Alumno solo su propio expediente. No devuelve DNI ni número de Seguridad Social.
POST	`/alumnos`	Administrador o Coordinador crea una cuenta y expediente. Un alumno menor de edad requiere el objeto `tutor` completo.
PATCH	`/alumnos/{id}`	Alumno modifica nombre, apellidos, correo y código postal de su propio expediente.
GET	`/empresas` y `/empresas/{id}`	Administrador, Coordinador y Observador consultan; Empresa solo ve su propia empresa.
POST	`/empresas`	Administrador o Coordinador crea una cuenta y perfil de empresa.
PATCH	`/empresas/{id}`	Empresa modifica nombre, web, categoría y pertenencia a grupo de su propia empresa.
GET	`/ofertas` y `/ofertas/{id}`	Consulta; Alumno ve ofertas aprobadas vigentes y Empresa solo sus ofertas.
POST	`/ofertas`	Empresa crea una oferta pendiente asociada a un convenio aprobado.
PATCH	`/ofertas/{id}`	Administrador aprueba o rechaza una oferta pendiente.
GET	`/convenios` y `/convenios/{id}`	Administrador, Coordinador y Observador consultan; Empresa solo sus convenios. No expone la ruta del PDF.
POST	`/convenios`	Empresa registra un convenio mediante `multipart/form-data`; el PDF se analiza con ClamAV y se almacena fuera de la carpeta pública.
PATCH	`/convenios/{id}`	Administrador revisa un convenio pendiente.
GET	`/asignaciones` y `/asignaciones/{id}`	Administrador, Coordinador y Observador consultan; Alumno ve sus asignaciones y Empresa las de sus ofertas.
POST	`/asignaciones`	Administrador o Coordinador asigna un alumno que cumpla las reglas actuales de disponibilidad, ciclo y cupo.
PATCH	`/asignaciones/{id}`	Administrador o Coordinador cierra una asignación activa.

Relación con los permisos MVC

`public/api.php` y `routes/web.php` aplican sus permisos por separado. En la implementación actual, tanto las rutas API `PATCH /ofertas/{id}` y `PATCH /convenios/{id}` como las acciones MVC `POST revisar-oferta` y `POST resolver-convenio` reservan la revisión a Administrador.

El Observador recibe vistas anonimizadas en las pantallas MVC, pero las respuestas REST actuales de `GET /alumnos` incluyen nombre, apellidos y correo, y `GET /asignaciones` incluye el nombre y apellidos del alumno. Esos recursos no devuelven DNI ni número de Seguridad Social. No asumas que la anonimización de la interfaz MVC se aplica a los tokens API; limita y protege esos tokens acorde con los datos que exponen.

No hay endpoints DELETE. La gestión de sedes permanece en los formularios actuales. Las cuentas se crean con contraseña inicial y los datos de alumnos se validan con las reglas de registro del sistema. Todas las escrituras registran auditoría.

Ejemplos

Consulta paginada de ofertas:

```
$apiBase = 'http://localhost/proyecto-practicas/public/api.php?path='
$headers = @{ Authorization = 'Bearer <API_TOKEN>' }
Invoke-RestMethod -Uri "${apiBase}ofertas&page=1&per_page=20" -Headers $headers
```

Crear oferta como Empresa:

```
$body = @{
    titulo = 'Prácticas de desarrollo web'
    especialidad_id = 1
    plazas = 2
    fecha_inicio = '2027-03-01'
    fecha_fin = '2027-06-15'
    turno = 'Indiferente'
    horarios = @(
        @{
            dia_semana = 1
            hora_inicio = '09:00'
            hora_fin = '17:00'
        }
    )
} | ConvertTo-Json

Invoke-RestMethod -Method Post `
    -Uri "${apiBase}ofertas" `
    -Headers $headers -ContentType 'application/json' -Body $body
```

Crear una cuenta de empresa como Administrador o Coordinador:

```
$company = @{
    email = 'contacto@empresa.example'
    password = 'ContraseñaInicialSegura'
    nif_persona_juridica = 'B12345674'
    nombre_comercial = 'Empresa FCT'
    telefono = '612345678'
    direccion = 'Calle Ejemplo 1, Madrid'
    persona_contacto = 'Persona de contacto'
} | ConvertTo-Json
Invoke-RestMethod -Method Post `
    -Uri "${apiBase}empresas" `
    -Headers $headers -ContentType 'application/json' -Body $company
```

La API acepta `nif_persona_juridica`; las integraciones existentes que aún envían el campo `cif` siguen siendo compatibles.

Crear un expediente de alumno como Administrador o Coordinador requiere `email`, `password`, `nombre`, `apellidos`, `fecha_nacimiento`, `dni`, `nss`, `telefono`, `direccion`, `codigo_postal` y `especialidad_id`. Para menores de 18 años añade `tutor` como objeto con `nombre`, `dni`, `nss`, `direccion`, `telefono` y `correo`. El campo opcional `tipo_documento` acepta `NIF_NIE_DNI` (predeterminado) o `PASAPORTE`. El primer tipo valida la letra de control; los pasaportes aceptan únicamente entre 6 y 15 caracteres alfanuméricos.

Registrar convenio con PDF aprobado por ClamAV:

```
curl.exe -X POST `
    -H "Authorization: Bearer <API_TOKEN>" `
    -F "numero_convenio=CONV-2027-001" `
    -F "especialidad_id=1" `
    -F "fecha_firma=2027-01-15" `
    -F "fecha_inicio=2027-03-01" `
    -F "fecha_fin=2027-06-30" `
    -F "archivo=@convenio.pdf;type=application/pdf" `
    'http://localhost/proyecto-practicas/public/api.php?path=convenios'
```

Asignar alumno y cerrar la práctica:

```
$assignment = @{
    oferta_id = 1
    alumno_id = 2
    tutor_empresa = 'Tutor de prácticas'
} | ConvertTo-Json
$created = Invoke-RestMethod -Method Post `
    -Uri "${apiBase}asignaciones" `
    -Headers $headers -ContentType 'application/json' -Body $assignment

$close = @{ estado = 'Cerrada' } | ConvertTo-Json
Invoke-RestMethod -Method Patch `
    -Uri "${apiBase}asignaciones/$($created.data.id)" `
    -Headers $headers -ContentType 'application/json' -Body $close
```

Actualizar el perfil de empresa autenticado:

```
$companyUpdate = @{
    nombre_empresa = 'Empresa FCT'
    pagina_web = 'https://empresa.example'
    categoria = 'Tecnología'
} | ConvertTo-Json
Invoke-RestMethod -Method Patch `
    -Uri "${apiBase}empresas/1" `
    -Headers $headers -ContentType 'application/json' -Body $companyUpdate
```

Para aprobar una oferta o convenio, usa `PATCH` sobre su ruta de detalle con `{"estado":"Aprobada"}` o `{"estado":"Aprobado"}`. Para rechazar, el estado debe ser `Rechazada` o `Rechazado` y debe incluir `motivo`.

Códigos de respuesta y despliegue

La API usa `200` para consultas y actualizaciones, `201` para creaciones, `400` para JSON o paginación inválidos, `401` para tokens ausentes o inválidos, `403` para roles no autorizados, `404` para recursos inexistentes, `405` para métodos no admitidos, `409` para conflictos de datos únicos (por ejemplo, convenios duplicados), `413` para cuerpos demasiado grandes, `415` cuando una escritura JSON no usa `Content-Type: application/json`, y `422` para datos que no cumplen las reglas del dominio. Si ClamAV no está disponible, registrar un convenio responde `503`. Errores inesperados se registran en el log del servidor y se responden con `500`.

La carga de PDF necesita los límites Apache/PHP documentados en el README, ClamAV operativo y `FCT_STORAGE_PATH` configurado fuera del document root. En producción, publica la API únicamente mediante HTTPS. No incluyas tokens en URLs, código fuente, repositorio, logs o capturas. Trata también contraseñas y datos personales enviados al crear expedientes como información confidencial.